Simulación y Análisis de Fase Inicial de Ransomware en Entorno Corporativo

Proyecto Mini-SOC – Anàlisis de Incidente Crítico

Autor: Javier Afonso

Especialización: Ciberseguridad – SOC Analyst

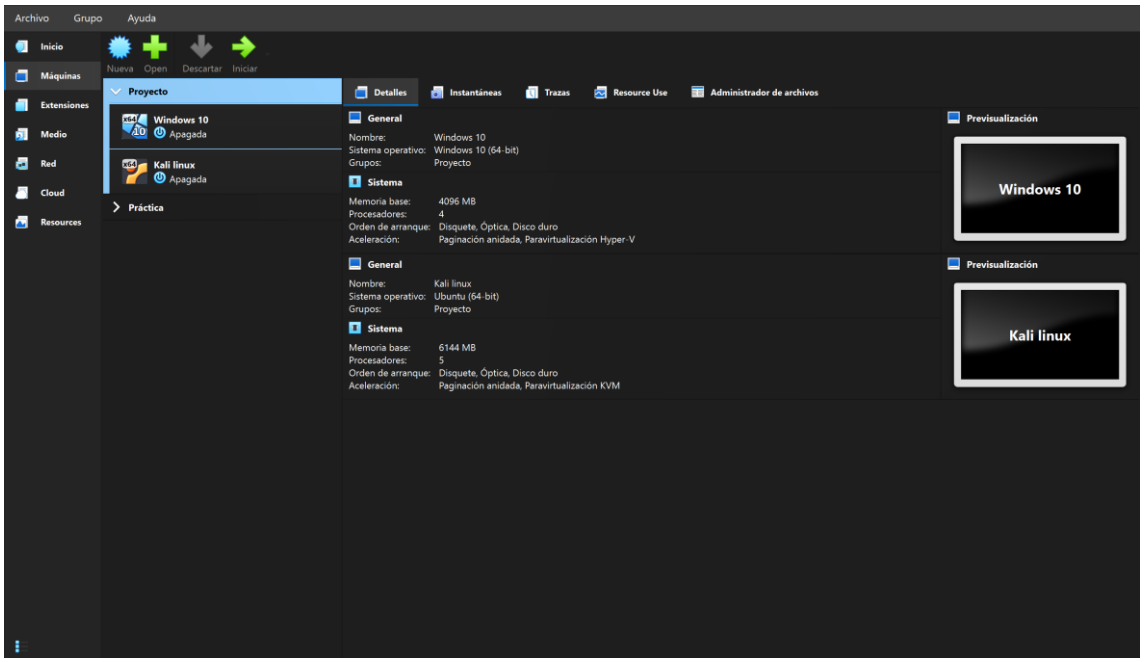
Año: 2026

ÍNDICE

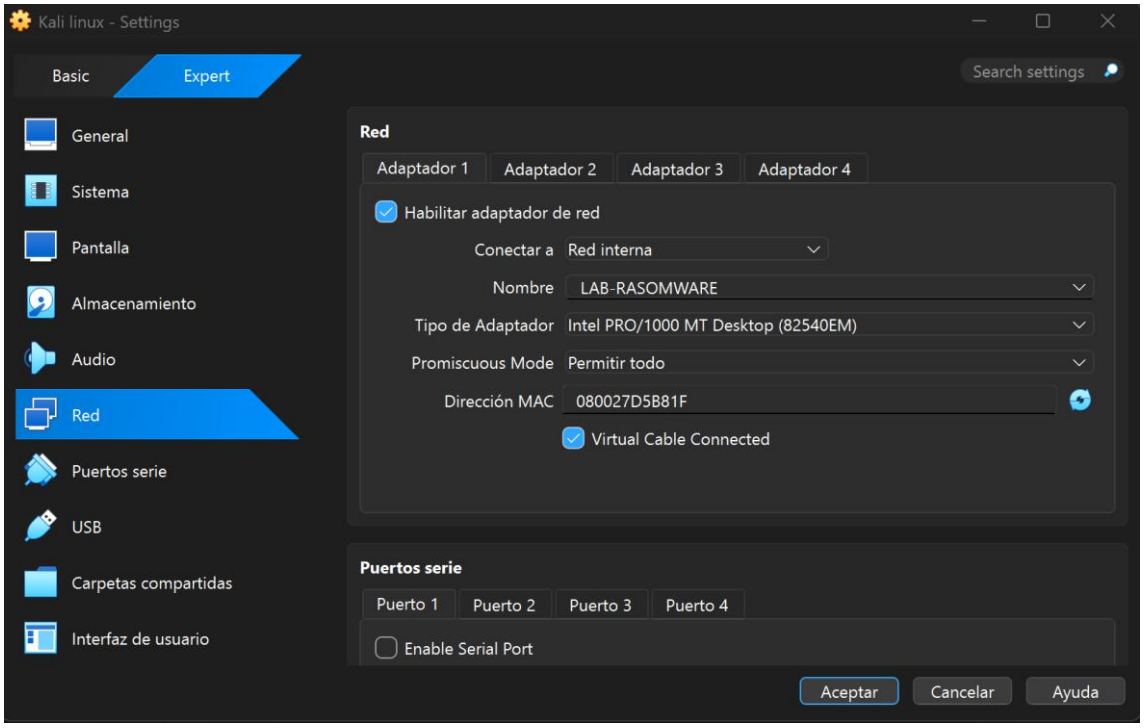
1. Introducción
2. Objetivo del proyecto
3. Descripción del entorno de laboratorio
4. Configuración de red
5. Configuración de auditoría avanzada
6. Simulación de comportamiento tipo ransomware
7. Análisis forense (Event ID 4688)
8. Evaluación del impacto y correlación del incidente
9. Conclusión
10. Recomendaciones de seguridad

1 — Preparación del caso y “estado inicial” del laboratorio

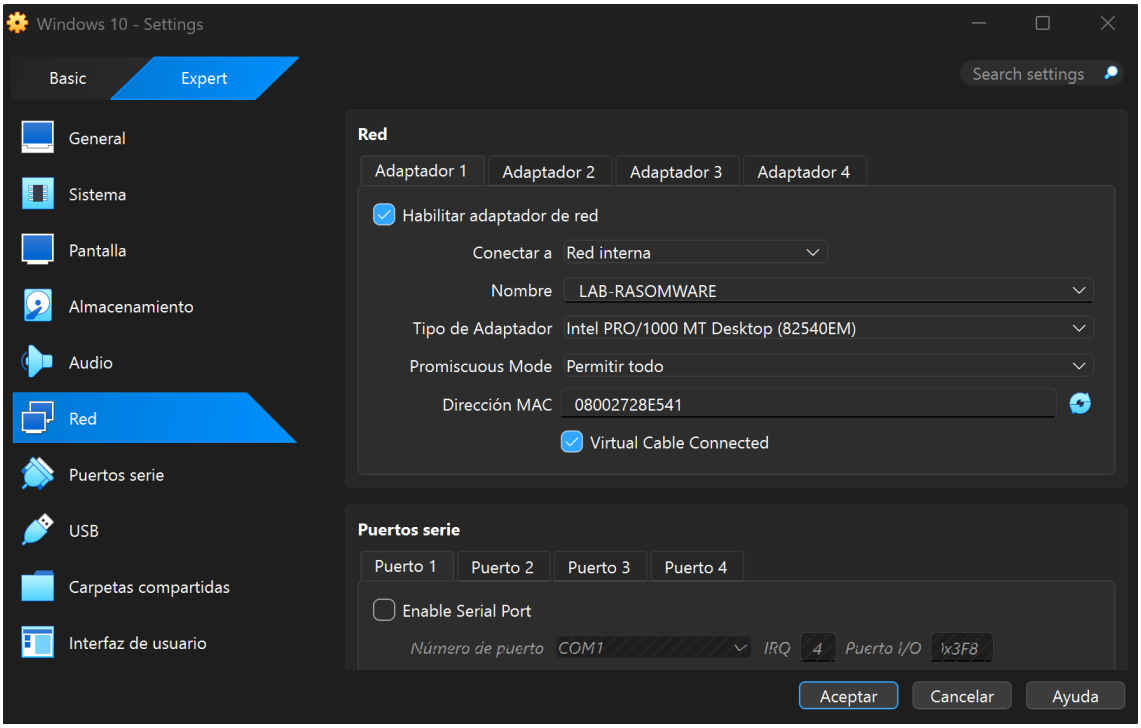
Se presenta el inventario del laboratorio virtualizado que se utilizará para la simulación del incidente: Kali Linux como sistema atacante/operador y Windows como sistema víctima donde se generarán las evidencias para el análisis.



Se configura la máquina Kali en una red interna aislada denominada “LAB-RANSOMWARE”, garantizando que el tráfico generado durante la simulación no afecte a la red real.

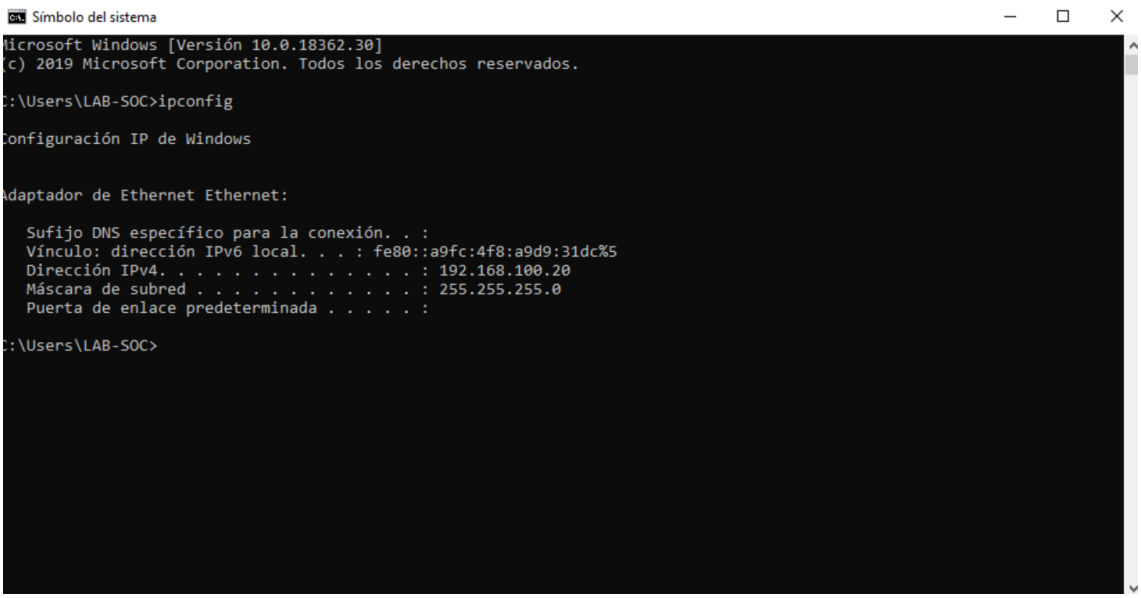


Se integra la máquina Windows en la misma red interna “LAB-RANSOMWARE” para permitir la simulación controlada del incidente y la generación de evidencias forenses.



3 — Asignación de IPs y verificación de conectividad

Se asigna una dirección IP estática al sistema Windows dentro del segmento interno 192.168.100.0/24, estableciendo un entorno controlado para la simulación del incidente.



Se confirma que Kali Linux tiene asignada la IP 192.168.100.10 dentro del mismo segmento que la máquina Windows.

```
LAB-SOC@kali: ~
Session  Acciones  Editar  Vista  Ayuda

┌──(LAB-SOC㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:d5:b8:1f brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.10/24 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fed5:b81f/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

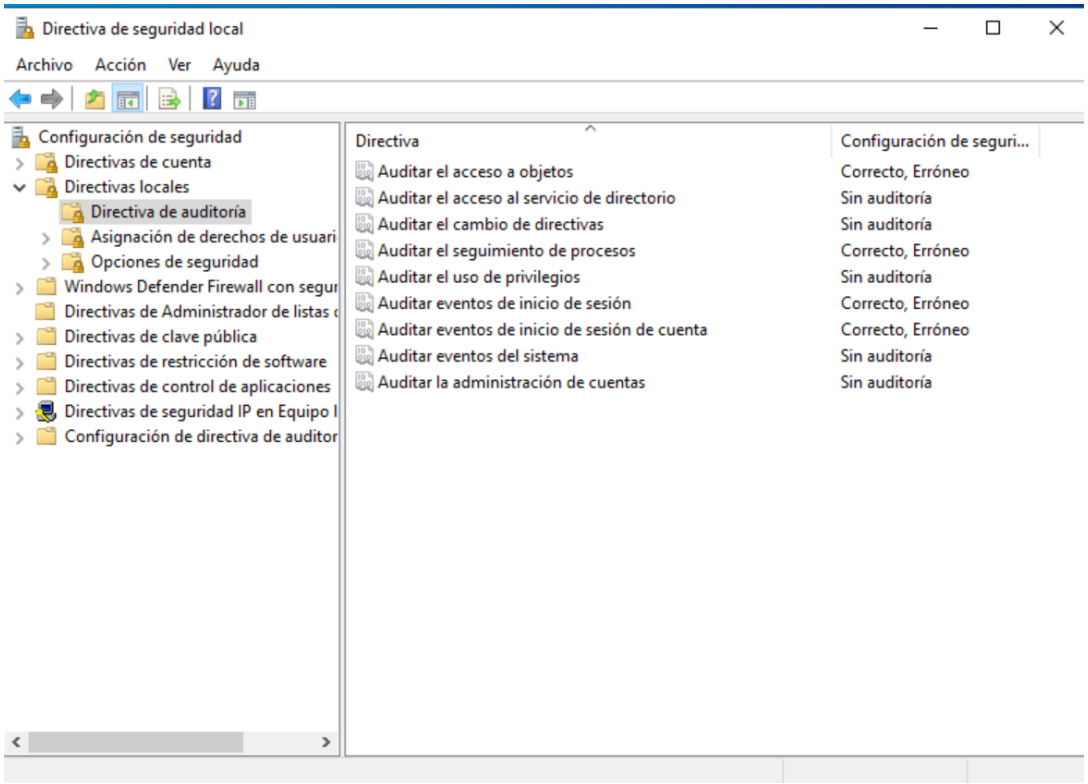
Se valida la conectividad entre ambas máquinas antes de iniciar la simulación, estableciendo el estado base del entorno.

```
LAB-SOC@kali: ~
Session  Acciones  Editar  Vista  Ayuda

┌──(LAB-SOC㉿kali)-[~]
└─$ ping -c 4 192.168.100.10
PING 192.168.100.10 (192.168.100.10) 56(84) bytes of data.
64 bytes from 192.168.100.10: icmp_seq=1 ttl=64 time=0.034 ms
64 bytes from 192.168.100.10: icmp_seq=2 ttl=64 time=0.039 ms
64 bytes from 192.168.100.10: icmp_seq=3 ttl=64 time=0.028 ms
64 bytes from 192.168.100.10: icmp_seq=4 ttl=64 time=0.041 ms

--- 192.168.100.10 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3408ms
rtt min/avg/max/mdev = 0.028/0.035/0.041/0.005 ms
```

```
Símbolo del sistema
Microsoft Windows [Versión 10.0.18362.30]
(c) 2019 Microsoft Corporation. Todos los derechos reservados.

C:\Users\LAB-SOC>ping 192.168.100.20

Haciendo ping a 192.168.100.20 con 32 bytes de datos:
Respuesta desde 192.168.100.20: bytes=32 tiempo<1m TTL=128
Respuesta desde 192.168.100.20: bytes=32 tiempo<1m TTL=128
Respuesta desde 192.168.100.20: bytes=32 tiempo<1m TTL=128
Respuesta desde 192.168.100.20: bytes=32 tiempo<1m TTL=128

Estadísticas de ping para 192.168.100.20:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 0ms, Media = 0ms
```

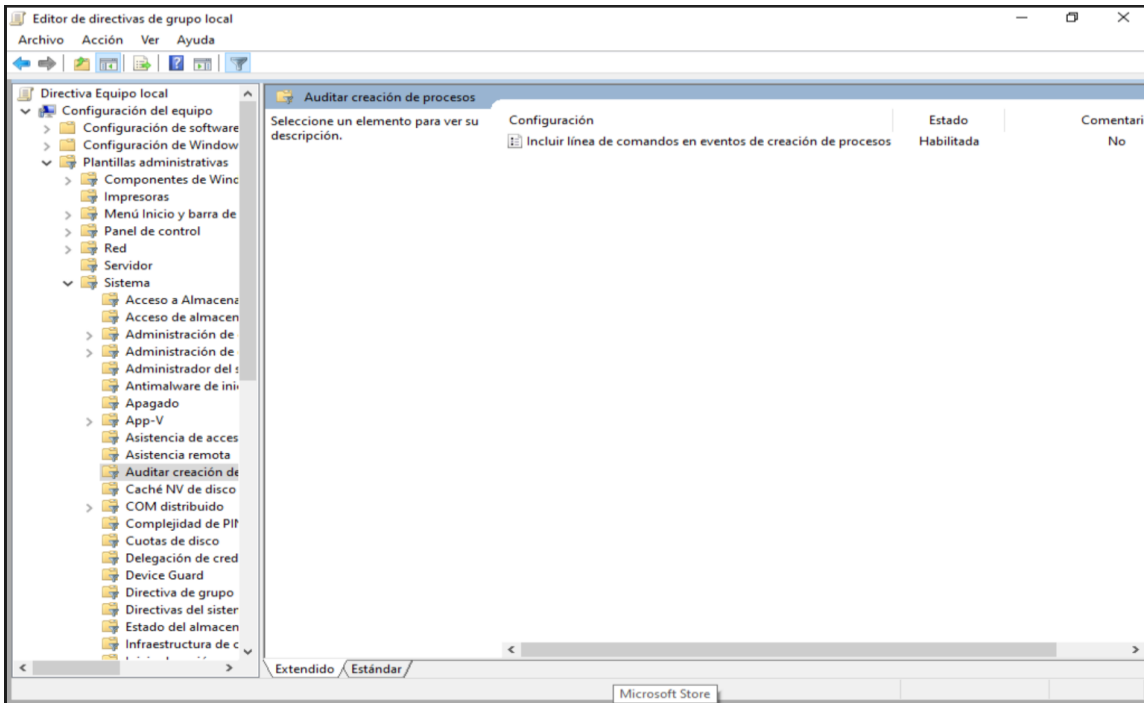
4 — Preparación avanzada de auditoría en Windows

Se habilitan auditorías avanzadas en Windows para registrar eventos críticos como creación de procesos y accesos a objetos, fundamentales para detectar comportamiento asociado a ransomware.



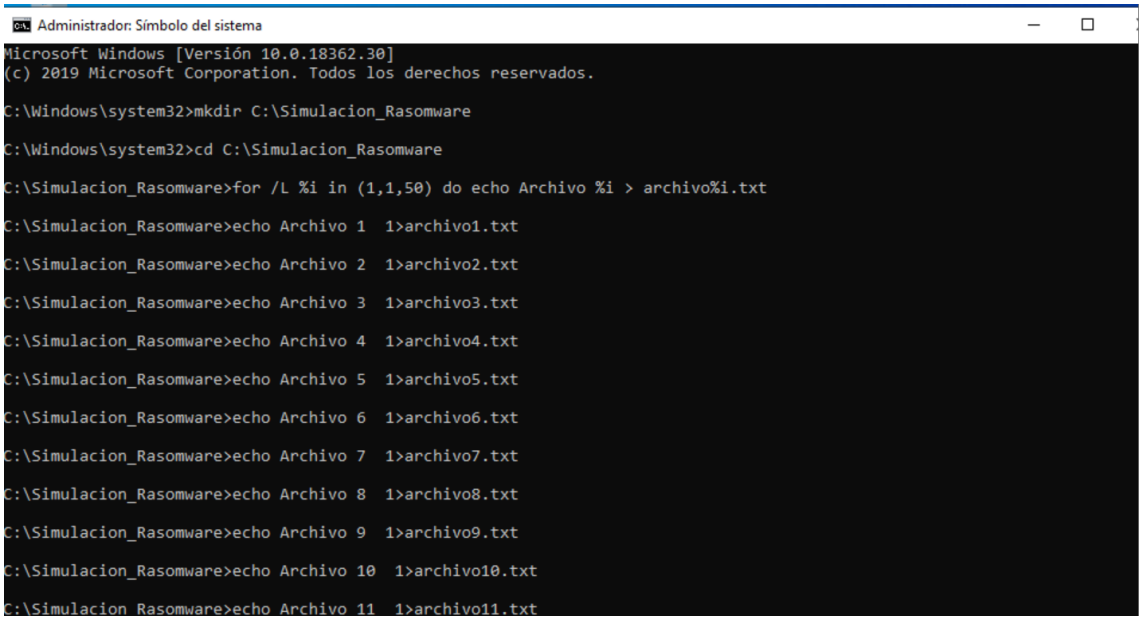
Se habilita la auditoría de creación de procesos mediante GUID para evitar problemas de localización del sistema. Esto garantiza el registro del Event ID 4688, clave para detectar ejecución de comandos asociados a comportamiento malicioso.

Se habilita el registro de línea de comandos en los eventos de creación de procesos. Esto permite visualizar exactamente qué comandos fueron ejecutados, lo que resulta fundamental en la detección de comportamiento previo a ransomware.



5) Generar actividad simulada tipo ransomware

Se genera actividad masiva de creación de archivos mediante un bucle en CMD. Este comportamiento es característico en fases iniciales de preparación de ransomware, donde se enumeran y manipulan múltiples archivos en un corto intervalo de tiempo.



6) Simulación de ejecución sospechosa con PowerShell

Se simula una actividad típica de ransomware mediante PowerShell, renombrando múltiples archivos para añadir una extensión “. locked". Este patrón es común en ataques reales donde los archivos son cifrados y modificados masivamente.

```
Administrador: Símbolo del sistema
Microsoft Windows [Versión 10.0.18362.30]
(c) 2019 Microsoft Corporation. Todos los derechos reservados.

C:\Windows\system32>powershell -Command "Get-ChildItem C:\Simulacion_Rasomware"


    Directorio: C:\Simulacion_Rasomware


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----       20/02/2026     10:26             12 archivo1.txt
-a----       20/02/2026     10:26             13 archivo10.txt
-a----       20/02/2026     10:26             13 archivo11.txt
-a----       20/02/2026     10:26             13 archivo12.txt
-a----       20/02/2026     10:26             13 archivo13.txt
-a----       20/02/2026     10:26             13 archivo14.txt
-a----       20/02/2026     10:26             13 archivo15.txt
-a----       20/02/2026     10:26             13 archivo16.txt
-a----       20/02/2026     10:26             13 archivo17.txt
-a----       20/02/2026     10:26             13 archivo18.txt
-a----       20/02/2026     10:26             13 archivo19.txt
-a----       20/02/2026     10:26             12 archivo2.txt
-a----       20/02/2026     10:26             13 archivo20.txt
-a----       20/02/2026     10:26             13 archivo21.txt
-a----       20/02/2026     10:26             13 archivo22.txt
-a----       20/02/2026     10:26             13 archivo23.txt
-a----       20/02/2026     10:26             13 archivo24.txt
-a----       20/02/2026     10:26             13 archivo25.txt
-a----       20/02/2026     10:26             13 archivo26.txt
```

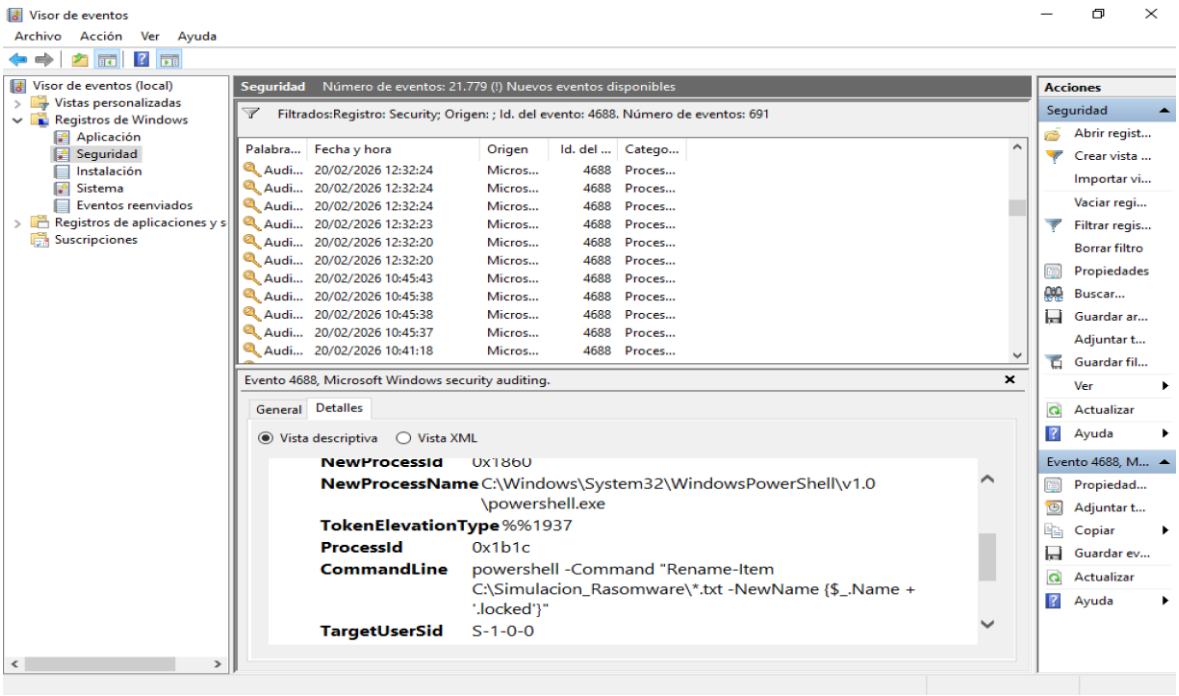
Se ejecuta un comando PowerShell que enumera los archivos mediante Get-ChildItem y los renombra agregando la extensión ".locked". Este patrón replica el comportamiento típico de cifrado masivo observado en ataques ransomware reales.

```
C:\Windows\system32>powershell -Command "Get-ChildItem C:\Simulacion_Rasomware\*.txt | Rename-Item -NewName {$_.Name +
.locked'}"

C:\Windows\system32>
```

7) Análisis en el Visor de Eventos (4688)

La captura muestra un evento 4688 en el registro de Seguridad, donde se registra la ejecución de powershell.exe. En el campo CommandLine se observa el comando que renombra masivamente archivos añadiendo la extensión ".locked", simulando el comportamiento típico de un ransomware.

Este registro demuestra que la auditoría avanzada permite identificar y analizar la actividad sospechosa realizada en el sistema.



8) Evaluación del impacto y detección empresarial

Tras el análisis de los eventos registrados en el sistema, se procede a evaluar el impacto potencial del comportamiento observado y su relevancia en un entorno empresarial real.

Durante la simulación se identificaron los siguientes indicadores de compromiso :

- Ejecución de powershell.exe registrada mediante Event ID 4688.
- Presencia de una línea de comandos que realiza modificación masiva de archivos.
- Renombrado simultáneo de múltiples archivos dentro de un mismo directorio.
- Actividad automatizada en un intervalo corto de tiempo.

Este tipo de comportamiento es característico de la fase inicial de un ataque ransomware, donde el malware comienza a cifrar o modificar archivos de manera masiva.

En un entorno corporativo real, el impacto potencial de esta actividad podría incluir:

- Pérdida de acceso a archivos críticos.
- Interrupción de la actividad operativa.
- Riesgo de propagación a otros equipos de la red.
- Daño reconocido y posibles pérdidas económicas.

Desde el punto de vista de un SOC, este comportamiento debería generar alertas automáticas basadas en:

- Creación de procesos sospechosos con PowerShell.
- Ejecución de comandos que manipulan múltiples archivos.
- Actividad masiva de modificación de archivos en corto periodo de tiempo.

La detección temprana de estos indicadores permitiría iniciar un proceso de contención antes de que el cifrado afecte a sistemas críticos.

Este análisis demuestra la importancia de contar con auditoría avanzada habilitada y con mecanismos de monitorización continua para identificar comportamientos anómalos antes de que se conviertan en incidentes graves.

9) Conclusión del proyecto

En este proyecto se simuló la fase inicial de un ataque ransomware en un entorno controlado, generando actividad sospechosa mediante CMD y PowerShell para modificar múltiples archivos de forma automatizada.

El análisis del Event ID 4688 permitió identificar la ejecución de powershell.exe junto con la línea de comandos utilizada para renombrar los archivos, demostrando que la auditoría avanzada permite reconstruir con precisión las acciones realizadas en el sistema.

Se identificaron indicadores claros de comportamiento malicioso, como la ejecución de comandos sospechosos y la modificación masiva de archivos en un corto intervalo de tiempo. En un entorno empresarial real, este tipo de actividad podría tener un impacto crítico si no se detecta de forma temprana.

El proyecto refuerza la importancia de la monitorización continua y del análisis de logs para la detección y respuesta ante incidentes de ransomware.

10) Recomendaciones de seguridad

Tras el análisis del comportamiento simulado, se proponen las siguientes medidas para prevenir y mitigar incidentes de ransomware en entornos empresariales:

- Implementar monitorización continua de eventos 4688 y ejecución de PowerShell.
- Restringir el uso de PowerShell mediante políticas de seguridad (Execution Policy y AppLocker).
- Aplicar el principio de mínimo privilegio a los usuarios.
- Mantener copias de seguridad periódicas y verificadas.
- Configurar alertas ante modificación masiva de archivos.
- Deshabilitar servicios innecesarios y aplicar actualizaciones de seguridad.
- Implementar soluciones EDR para detección de comportamiento anómalo.

Estas medidas reducen significativamente la probabilidad de éxito de ataques ransomware y permiten una detección temprana antes de que el impacto sea crítico.